

SOC/L1 - 8.1. Web Security Essentials

Task 1 - Introduction

Websites and web applications are among attackers' most targeted assets. Whether you're defending a company's website or investigating an incident, understanding how the web works and how to secure it is crucial.

Task 2 - Why Web?

The shift from desktop to web-based applications has been ongoing for decades. The risks faced by both web app owners and their users.

As a Web App Owner	As a Web App User
Your web application is always online and must be secured 24/7	Your data is stored in a web application, potentially insecurely
Anyone around the world can access your app at any time	Once your browser is breached, all of your accounts are at risk
It is challenging to stay up to date with so many emerging threats	A breach can result in identity theft or financial loss
You have the responsibility of securing your users' data	Your privacy can be permanently compromised

Answer the questions below

Have applications shifted from desktop to web over the past couple of decades? Yea

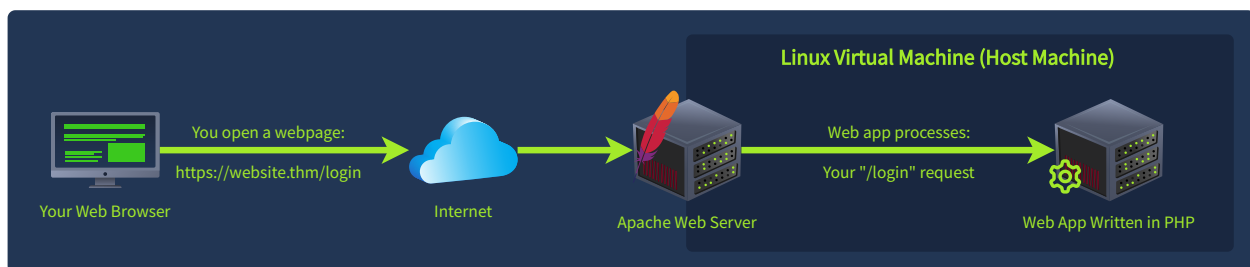
Who is ultimately responsible for ensuring the security of users' data within a web application? Web App Owner

Task 3 - Web Infrastructure

When you visit a website, your browser sends a request to a web server. The server processes the request, verifies access, and returns a response to the user. This response can be a webpage, an image, or data like search results or your

account information. This request-response cycle is the foundation of how the web functions. Attackers can abuse this request-response cycle by overwhelming servers with requests, bypassing access controls, or even tricking the server into executing harmful commands. Components of a Web Service

- **Application:** The code, images, styles, and icons that dictate how the website looks and functions.
- **Web Server:** This component hosts the application. It listens for requests and returns a response to the user.
- **Host Machine:** The underlying operating system, Linux or Windows, that runs the web server and the application



Web Servers: Web servers listen for incoming requests and return an appropriate response. Web servers are positioned in front of websites and applications, making them a crucial aspect of the internet's foundation. Because they are publicly exposed and handle all incoming web requests, web servers are a common target for attackers.

Here are some of the most common web servers:

- **Apache(opens in new tab):** The most popular web server to host simple websites and blogs, most commonly WordPress(opens in new tab).
- **Nginx(opens in new tab):** An industry standard for high-performance web apps. Used by companies like Netflix(opens in new tab), Airbnb, and GitHub.
- **Internet Information Services(opens in new tab) (IIS):** A Microsoft-developed web server commonly used in enterprise environments.

Answer the questions below

What does your web browser send to a server to receive a web page? Request

What web server is most commonly used to host WordPress websites? Apache

What do we call the OS and environment that runs the web server and application? Host Machine

Task 4 - Protecting the Web

Protecting the Application

- Secure Coding: Avoid insecure functions, ensure proper handling of errors, and remove sensitive information.
- Input Validation & Sanitization: Validate and sanitize user input to prevent injection attacks.
- Access Control: Restrict access based on user roles.

Protecting the Web Server

- Logging: Keep a detailed record of all web requests with access logs.
- Web Application Firewall (WAF): Filter and block harmful traffic based on defined rules.
- Content Delivery Network (CDN): Reduce direct exposure to your server and use integrated WAFs.

Protecting the Host Machine

- Least Privilege: Use low-privilege users for services.
- System Hardening: Disable unnecessary services and close unused ports.
- Antivirus: Add endpoint-level protection that blocks known malware.

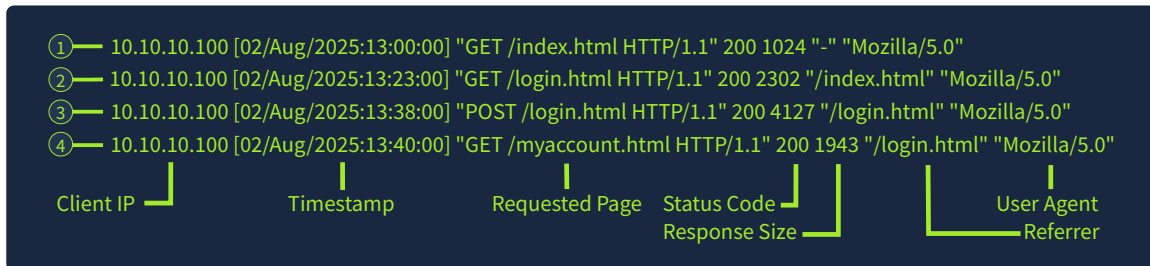
Security Tips for All Three Components

- Strong Authentication: Don't just let anyone access your code, admin panels, or host machine.
- Patch Management: Ensure your app dependencies, web server, and host machine are up to date.

Logging: Note that `GET` requests are used to retrieve a resource from the server, like a specific web page. `POST` requests are used to submit data to the server, such as login credentials.

1. The user, from the client IP `10.10.10.100`, visits the website's homepage at `/index.html`.
2. Next, they navigate to the login page at `/login.html`.
3. They then enter their credentials and submit the form, signified by the `POST` request.
4. Finally, they access their account page at `/myaccount.html`.

Although this series of events is expected and not out of the ordinary, you can see how the verbosity of these logs can help analysts and incident responders reconstruct a possible attack sequence.



Answer the questions below

What cyber security concept involves stopping or limiting damage from threats?
Mitigation

What security control involves ensuring all software and components are up to date? Patch Management

Task 5 - Defense Systems

Content Delivery Network (CDN): A Content Delivery Network (CDN) uses a global network of distributed servers to speed up content delivery, reduce latency, and enhance security for users everywhere.

Security Benefits

- IP Masking: Hides the origin server IP address, which makes it harder for attackers to target.
- DDoS Protection: CDNs can absorb a large amount of traffic, making denial-of-service attacks less effective.

- Enforced HTTPS: Encrypted communication via TLS is enforced by default by most CDNs.
- Integrated WAF: Many CDNs, including [Cloudflare CDN\(opens in new tab\)](#), [Amazon CloudFront\(opens in new tab\)](#) & [Azure Front Door\(opens in new tab\)](#), integrate web application firewalls.

Web Application Firewall (WAF): A Web Application Firewall (WAF) acts as a digital bouncer that inspects incoming web traffic and filters out malicious requests before they can reach your application. Their functionality.

- Cloud-based (Reverse Proxy): Sits in front of the web server. These WAFs are easy to deploy and have great scalability.
- Host-based: Software deployed directly on the web server and offers control for each application.
- Network-based: A physical or virtual appliance situated on the network perimeter. More suited for enterprise environments.

WAF Feature	Detection Method	Example
Signature-Based Detection	Matches known attack patterns or payloads	A request with a User-Agent that matches a known tool, <code>sqlmap/1.8.1</code>
Heuristic-Based Detection	Analyzes the context and behavior of requests	A long query string with special characters <code>search?q=%3Cscript%20(1)</code>
Anomaly & Behavioral Analysis	Flags deviations from normal traffic behavior	A single IP address makes repeated login attempts in a short period of time
Location & IP Reputation Filtering	Uses location and threat intel to block IPs	A request from an IP address that is outside of your normal business area

Antivirus (AV): Antivirus (AV) software safeguards individual devices by scanning for known malware, serving as a critical layer of host defense rather than complete protection.

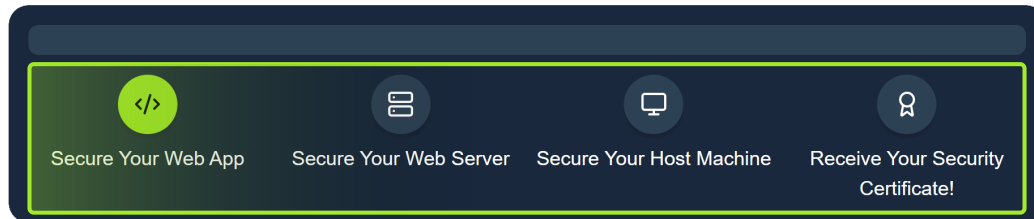
Answer the questions below

Which type of Web Application Firewall operates by running on the same system as the application itself? Host-Based

Which common WAF detection technique works by matching incoming requests against known malicious patterns? Signature-Based

Task 6 - Practice Scenario

Open **Secure-A-Site** by clicking the **View Site** button above. Once you complete each section, claim the flags and answer the task questions!



Answer the questions below

What flag did you receive for securing the Web Application?

THM{web_app_secured!}

What flag did you receive for securing the Web Server?

THM{server_security_expert!}

What flag did you receive for securing the Host Machine?

THM{the_final_security_layer!}